

Roadmap: Acreditación PSC Chile — Goya Ledger

Contexto

El código de Goya Ledger ya implementa los 5 bloqueantes técnicos para FEA (SigningCertificateV2, certificate embedding, NTP enforcement, policy OID, commitment type). Este roadmap cubre **todo lo que falta** — código, infraestructura, legal, auditoría — para llegar a PSC acreditado ante la Subsecretaría de Economía.

No es un plan de implementación de código. Es un documento de referencia para el proyecto completo.

Fase 0 — Ya hecho (código)

Item	Estado
CAdES-BES/T DER con ETSI signed attrs	✓
TSA RFC 3161 DER + NTP enforcement	✓
PKCS#11 adapter (HsmSigningProvider)	✓
CP/CPS markdown export + API	✓
Interop x509-parser + OpenSSL asn1parse	✓
CAVP NIST SHA-256 + Ed25519 RFC 8032	✓
Audit log JSON export con hash chain	✓
Key ceremony framework con M-of-N	✓
OCSP responder RFC 6960	✓
CRL RFC 5280	✓
RA con validación RUT	✓
Biometría ISO 19794-2	✓
2365+ tests passing	✓

Fase 1 — Preparación legal (Mes 1-2)

Costo estimado: USD 3-5K

#	Acción	Responsable	Dependencia
1.1	Constituir persona jurídica chilena (SpA o SRL)	Abogado corporativo	—
1.2	Obtener RUT de la sociedad	SII	1.1
1.3	Contratar seguro de responsabilidad civil (Art. 14 Ley 19.799)	Broker seguros	1.1
1.4	Contratar abogado especialista en firma electrónica para revisar CPS	Abogado FE	1.1
1.5	Publicar CPS en URL pública (ej. goya.cl/pki/cps)	DevOps	1.4
1.6	Registrar dominio goya.cl si no existe	—	—

Entregable: Sociedad constituida, CPS publicado, seguro contratado.

Fase 2 — Infraestructura HSM + Datacenter (Mes 2-4)

Costo estimado: USD 15-25K inicial + USD 1-2K/mes

#	Acción	Costo	Notas
2.1	Comprar HSM FIPS 140-2 Level 3	USD 12-20K	Thales Luna Network HSM 7 o Entrust nShield Connect. Debe soportar EdDSA (CKM_EDDSA). Verificar con vendor antes de comprar.
2.2		USD 1-2K/mes	

#	Acción	Costo	Notas
	Contratar colocation Tier III en Chile		Gtd, Entel DC, IFX Networks. Mínimo: rack 1/4, redundancia N+1, UPS.
2.3	Configurar sala de ceremonias	Incluido en colo	Cuarto con CCTV, control de acceso, registro de visitantes. DS 181 lo exige para key ceremony.
2.4	Conectar HSM via PKCS#11	Código ya listo	cargo build --features hsm. Instalar SoftHSM2 primero para validar, luego conectar hardware real.
2.5	Ejecutar key ceremony formal	—	Usar KeyCeremony de src/pki_ceremony.rs. Requiere: 3 custodians, 2 witnesses, 1 notary. Documentar con video + acta notarial.
2.6	Generar CA root + intermediate en HSM	—	CaHierarchy::generate() pero con HsmSigningProvider en vez de software. Root key offline, intermediate operacional.

Entregable: HSM operacional, claves CA generadas con ceremonia documentada, nodo corriendo en datacenter.

Fase 3 — Consultor PSC + pre-auditoría (Mes 3-5)

Costo estimado: USD 5-10K

#	Acción	Notas
3.1	Contratar consultor que haya acreditado un PSC antes	Ex-empleado de E-Sign, Acepta, o TOC. Conoce el proceso exacto y los documentos que pide la Subsecretaría.
3.2	Gap analysis formal	El consultor revisa código + docs + infra contra DS 181 y Decreto 24. Produce lista de brechas.
3.3	Corregir brechas identificadas	Variable. Típicamente: ajustes al CPS, procedimientos operacionales, políticas de personal.
3.4	Mock audit interno	Simular la auditoría con el consultor como auditor.

#	Acción	Notas
		Identificar lo que va a preguntar la Entidad Acreditadora.
3.5	Pruebas de interoperabilidad con PSCs existentes	Verificar que firmas CAdES-T producidas por Goya sean validables por E-Sign/Acepta y viceversa.

Entregable: Gap analysis cerrado, mock audit pasado, interop confirmado.

Fase 4 — Auditoría externa + solicitud formal (Mes 5-8)

Costo estimado: USD 15-30K

#	Acción	Notas
4.1	Contratar auditor externo acreditado	DS 181 Art. 17. Opciones: EY, Deloitte, BDO, o firma local especializada.
4.2	Auditoría de seguridad	Incluye: pruebas de penetración, revisión de controles físicos, revisión de procedimientos operacionales.
4.3	Preparar carpeta de acreditación	Formulario de la Subsecretaría de Economía + todos los anexos: CPS, informe auditor, póliza seguro, escritura social, etc.
4.4	Presentar solicitud a Subsecretaría de Economía	Trámite administrativo. La Subsecretaría deriva a la Entidad Acreditadora (actualmente: INN).
4.5	Inspección de la Entidad Acreditadora	Visita presencial al datacenter + revisión documental.
4.6	Resolución de acreditación	30-60 días hábiles desde la inspección.

Entregable: Acreditación como PSC.

Fase 5 (opcional) — FIPS 140-3 (Mes 6-18, paralelo)

Costo estimado: USD 50-100K

No es requisito legal chileno, pero fortalece la propuesta comercial.

#	Acción	Notas
5.1	Seleccionar CMVP testing lab	atsec, Leidos, UL. Ver docs/compliance/fips_submission/LAB_SELECTION.md.
5.2	Completar CAVP algorithm testing (ACVP)	SHA-256, Ed25519, ML-DSA-65, RSA, AES-GCM. Los KAT ya existen pero necesitan formato ACVP.
5.3	Escribir Security Policy formal	Documento FIPS obligatorio. Template en docs/compliance/fips_submission/.
5.4	Enviar módulo a testing	6-12 meses de proceso.

Timeline resumido

Mes 1-2: [===== Fase 1: Legal =====]
Mes 2-4: [===== Fase 2: HSM + DC =====]
Mes 3-5: [===== Fase 3: Consultor =====]
Mes 5-8: [===== Fase 4: Auditoría =====] → PSC
✓
Mes 6-18: [===== Fase 5: FIPS (opcional) =====]
=====]

Primer paso concreto: Fase 1.1 — constituir la sociedad. Todo lo demás depende de eso.

Costos totales estimados

Concepto	Mínimo	Máximo
Legal (sociedad + abogado FE + seguro)	USD 3K	USD 5K
HSM	USD 12K	USD 20K
Datacenter (primer año)	USD 12K	USD 24K
Consultor PSC	USD 5K	USD 10K
Auditoría externa	USD 15K	USD 30K
Total sin FIPS	USD 47K	USD 89K
FIPS 140-3 (opcional)	USD 50K	USD 100K

Verificación

Este roadmap no requiere verificación de código — es un documento de planificación. Los items de código (Fase 0) ya están verificados con 2365 tests passing, fmt ✓, clippy ✓.